**Laboratorio #12.1:**

**Objetivos:**

- Ejecutar los tres escaneos empaquetados de OWASP ZAP (baseline, API y full) desde Docker contra Juice Shop.
- Interpretar alertas pasivas (cabeceras, CORS, cookies) y activas (inyección, errores 5xx).
- Definir un gate con rules.conf: qué bloquea el pipeline, qué solo avisa y qué se ignora.
- Integrar DAST como stage de GitLab CI usando services para levantar la app efímera.
- Enviar el reporte ZAP a DefectDojo junto con los de Gitleaks, TruffleHog, Trivy y Semgrep.

**Guías de laboratorio:**

- https://github.com/utec-devops-2026/laboratorios/blob/main/laboratorios_devsecops/guia_dast_zap.md
- https://github.com/utec-devops-2026/laboratorios/blob/main/laboratorios_devsecops/ejemplo_intro_dast.md (previo opcional, 20 min)

## Entregables

1. **URL de repositorio** (GitLab).
    - https://gitlab.com/aaron.timana/juice-shop-devsecops-20262/-/tree/codex/lab12-1-dast

2. Subir su repositorio a GitLab y brindar acceso al usuario @pytuxi.

3. **Capturas de los escaneos manuales:**
    - Resumen del baseline (Parte 2.2): WARN-NEW: 7 … PASS: 61 y exit=2.

```
PASS: Java Serialization Object [90002]
PASS: Sub Resource Integrity Attribute Missing [90003]
PASS: Charset Mismatch [90011]
PASS: Application Error Disclosure [90022]
PASS: WSDL File Detection [90030]
PASS: Loosely Scoped Cookie [90033]
WARN-NEW: Content Security Policy (CSP) Header Not Set [10038] x 5
        http://juice:3000 (200 OK)
        http://juice:3000/ftp (200 OK)
        http://juice:3000/ftp/eastere.gg (403 Forbidden)
        http://juice:3000/ftp/encrypt.pyc (403 Forbidden)
        http://juice:3000/sitemap.xml (200 OK)
WARN-NEW: Storable and Cacheable Content [10049] x 6
        http://juice:3000/robots.txt (200 OK)
        http://juice:3000/assets/public/favicon_js.ico (200 OK)
        http://juice:3000/chunk-DBPdFzgj.js (200 OK)
        http://juice:3000/polyfills.js (200 OK)
        http://juice:3000/rolldown-runtime-BoHGiXSq.js (200 OK)
WARN-NEW: Deprecated Feature Policy Header Set [10063] x 5
        http://juice:3000 (200 OK)
        http://juice:3000/chunk-DBPdFzgj.js (200 OK)
        http://juice:3000/polyfills.js (200 OK)
        http://juice:3000/rolldown-runtime-BoHGiXSq.js (200 OK)
        http://juice:3000/sitemap.xml (200 OK)
WARN-NEW: Cross-Domain Misconfiguration [10098] x 5
        http://juice:3000 (200 OK)
        http://juice:3000/chunk-DBPdFzgj.js (200 OK)
        http://juice:3000/robots.txt (200 OK)
        http://juice:3000/rolldown-runtime-BoHGiXSq.js (200 OK)
        http://juice:3000/styles.css (200 OK)
WARN-NEW: Modern Web Application [10109] x 5
        http://juice:3000 (200 OK)
        http://juice:3000/ (200 OK)
        http://juice:3000/juice-shop/build/routes/fileServer.js:68:18 (200 OK)
        http://juice:3000/juice-shop/node_modules/express/lib/router/layer.js:95:5 (200 OK)
        http://juice:3000/sitemap.xml (200 OK)
WARN-NEW: Dangerous JS Functions [10110] x 2
        http://juice:3000/chunk-Cv2YgWUq.js (200 OK)
        http://juice:3000/main.js (200 OK)
WARN-NEW: Cross-Origin-Embedder-Policy Header Missing or Invalid [90004] x 10
        http://juice:3000 (200 OK)
        http://juice:3000/ (200 OK)
        http://juice:3000/ftp (200 OK)
        http://juice:3000/juice-shop/node_modules/express/lib/router/layer.js:95:5 (200 OK)
        http://juice:3000/sitemap.xml (200 OK)
FAIL-NEW: 0     FAIL-INPROG: 0  WARN-NEW: 7     WARN-INPROG: 0  INFO: 0 IGNORE: 0       PASS: 61
exit=2
usuario@MacBookPro juice-shop-devsecops %
```

- Baseline con zap/rules.conf mostrando FAIL-NEW y exit=1 (Parte 3.3).

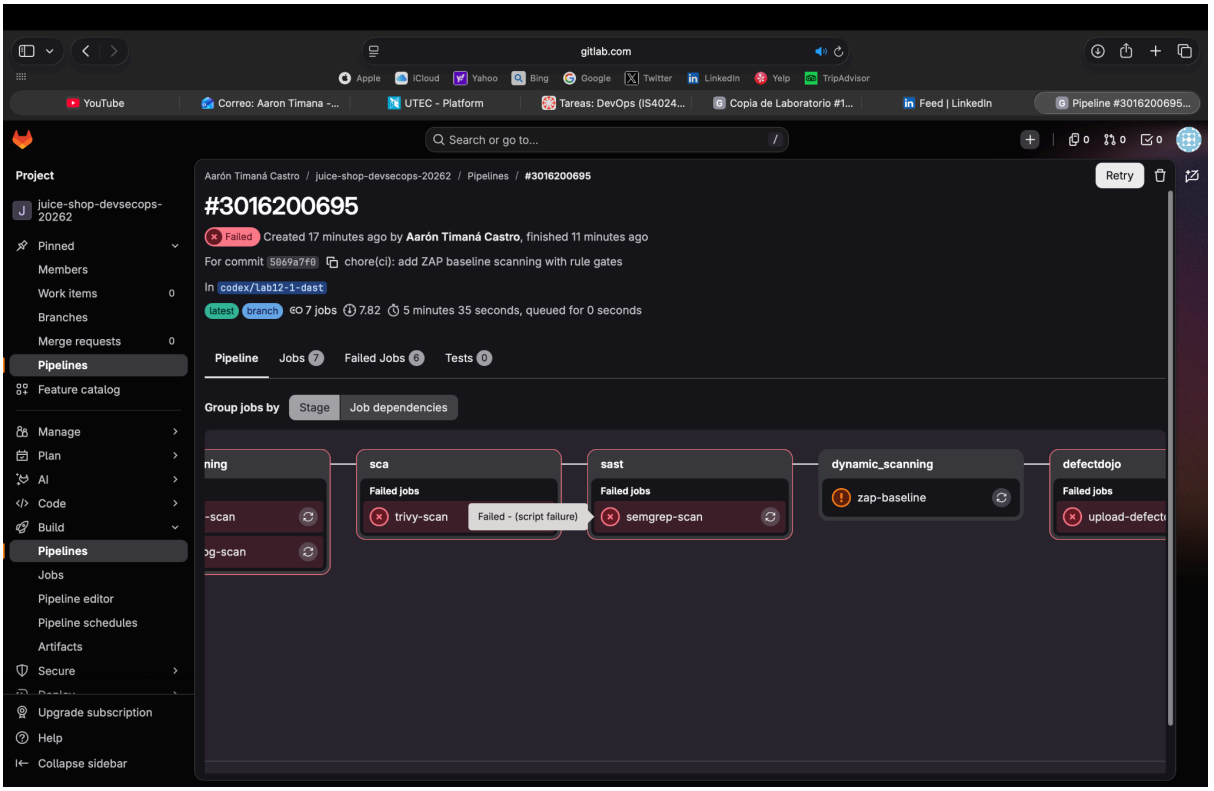
```
echo "exit=$?"
Using the Automation Framework
IGNORE: Storable and Cacheable Content [10049] x 6
IGNORE: Modern Web Application [10109] x 5
WARN-NEW: Deprecated Feature Policy Header Set [10063] x 5
WARN-NEW: Dangerous JS Functions [10110] x 2
WARN-NEW: Cross-Origin-Embedder-Policy Header Missing or Invalid [90004] x 10
FAIL-NEW: Content Security Policy (CSP) Header Not Set [10038] x 5
FAIL-NEW: Cross-Domain Misconfiguration [10098] x 4
FAIL-NEW: 2     FAIL-INPROG: 0  WARN-NEW: 3     WARN-INPROG: 0  INFO: 0 IGNORE: 2       PASS: 61
exit=1
usuario@MacBookPro juice-shop-devsecops %
```

- Resumen del API scan sobre swagger.yml (Parte 4.2).

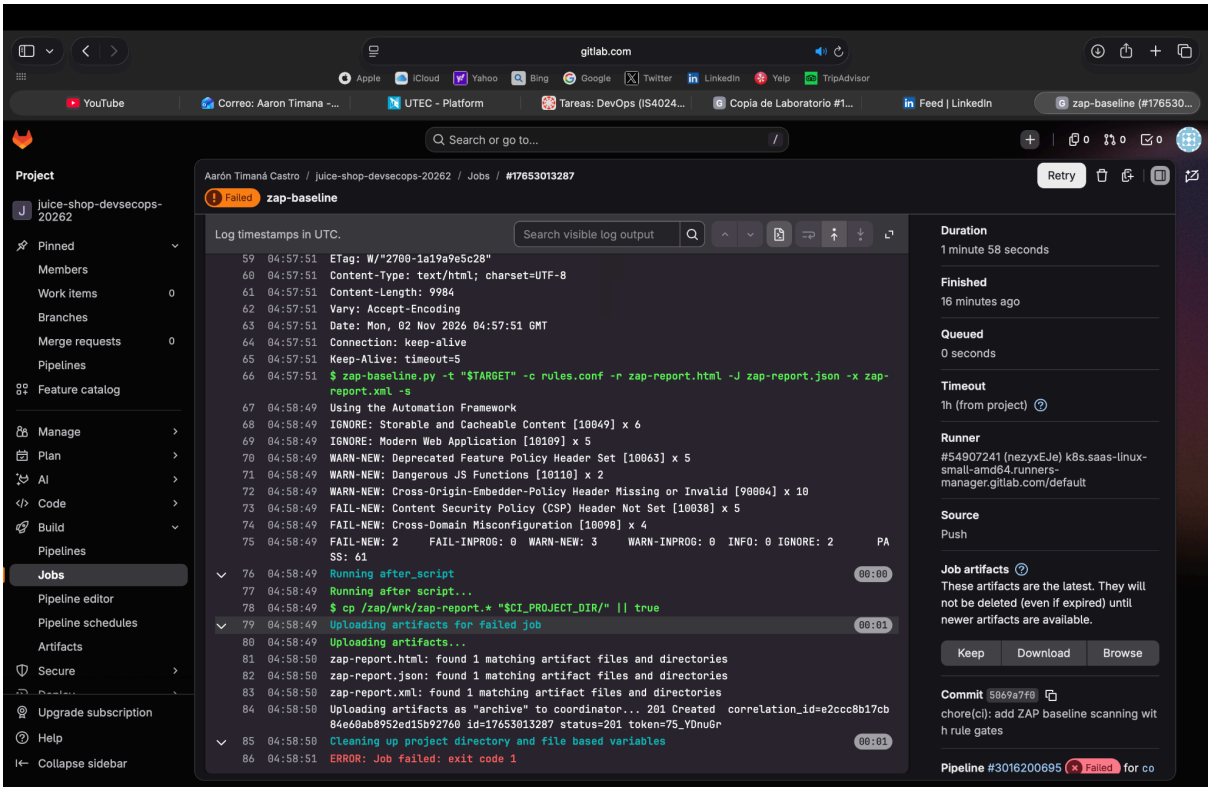
```
WARN-NEW: A Server Error response code was returned by the server [100000] x 9
        http://juice:3000/b2b/v2/orders (500 Internal Server Error)
        http://juice:3000/latest/meta-data/ (500 Internal Server Error)
        http://juice:3000/computeMetadata/v1/ (500 Internal Server Error)
        http://juice:3000/opc/v1/instance/ (500 Internal Server Error)
        http://juice:3000/opc/v2/instance/ (500 Internal Server Error)
WARN-NEW: Unexpected Content-Type was returned [100001] x 8
        http://juice:3000/6308696886537471472 (200 OK)
        http://juice:3000/4536749231229362435 (200 OK)
        http://juice:3000/b2b/7827614678424809569 (200 OK)
        http://juice:3000/b2b/648310380922785650 (200 OK)
        http://juice:3000 (200 OK)
WARN-NEW: Cross-Domain Misconfiguration [10098] x 1
        http://juice:3000/b2b/v2/orders (500 Internal Server Error)
WARN-NEW: Application Error Disclosure [90022] x 1
        http://juice:3000/b2b/v2/orders (500 Internal Server Error)
FAIL-NEW: 0     FAIL-INPROG: 0  WARN-NEW: 4     WARN-INPROG: 0  INFO: 0 IGNORE: 0       PASS: 118
exit=2
usuario@MacBookPro juice-shop-devsecops %
```

4. **Captura del job zap-baseline en GitLab**: Pipeline con job y log con el resumen y pestaña Artifacts con zap-report.* (Parte 6).

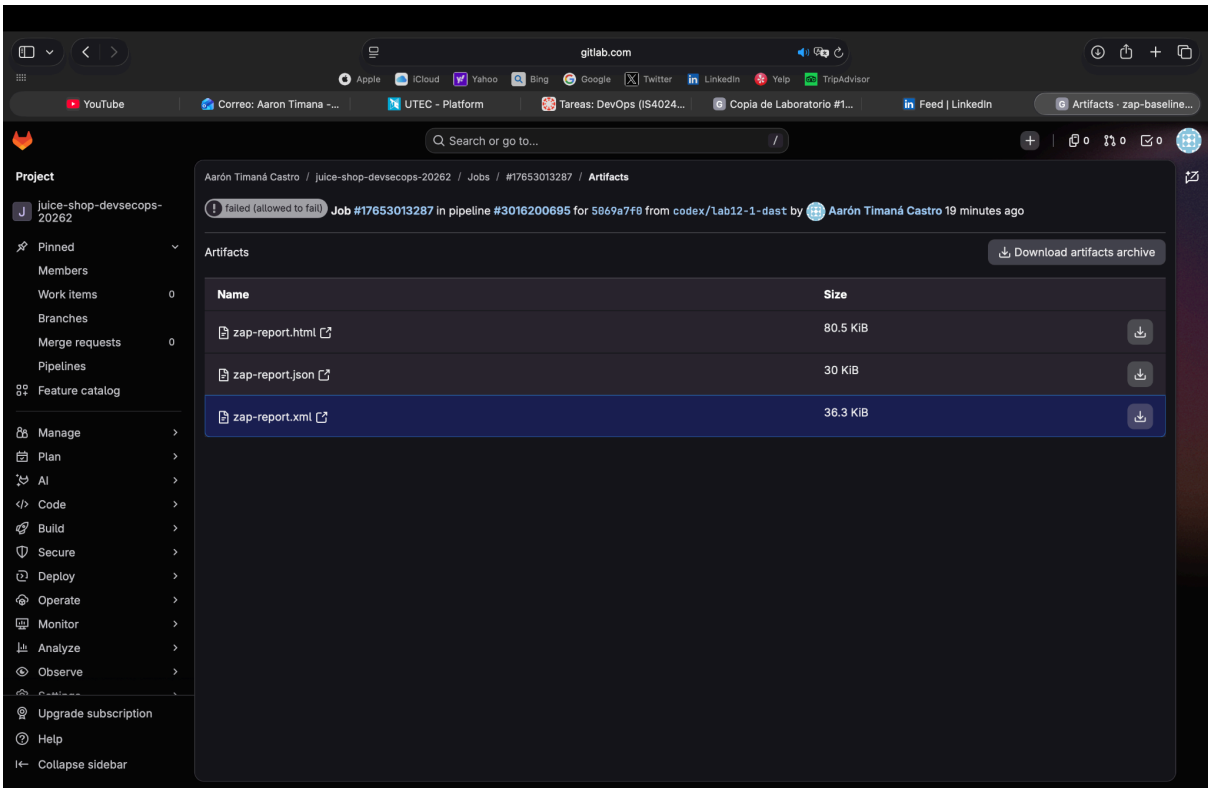
   pipeline:



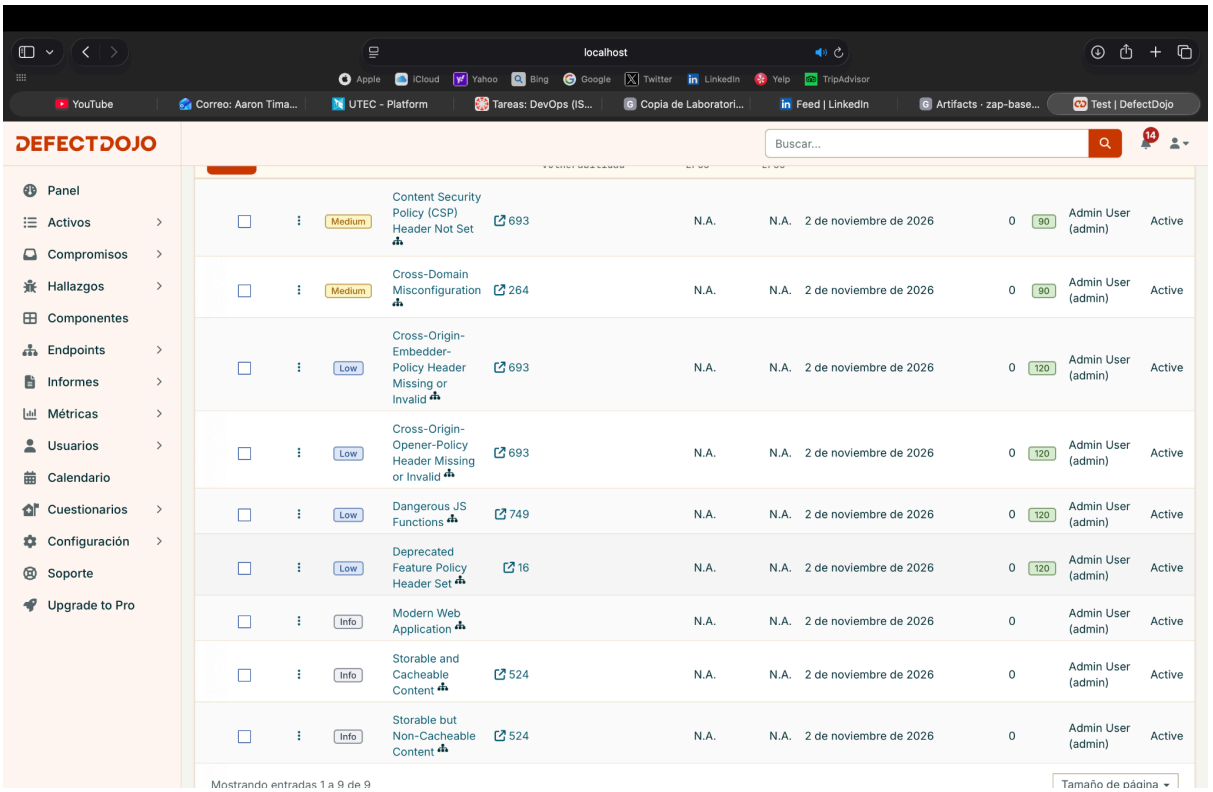

   Log:

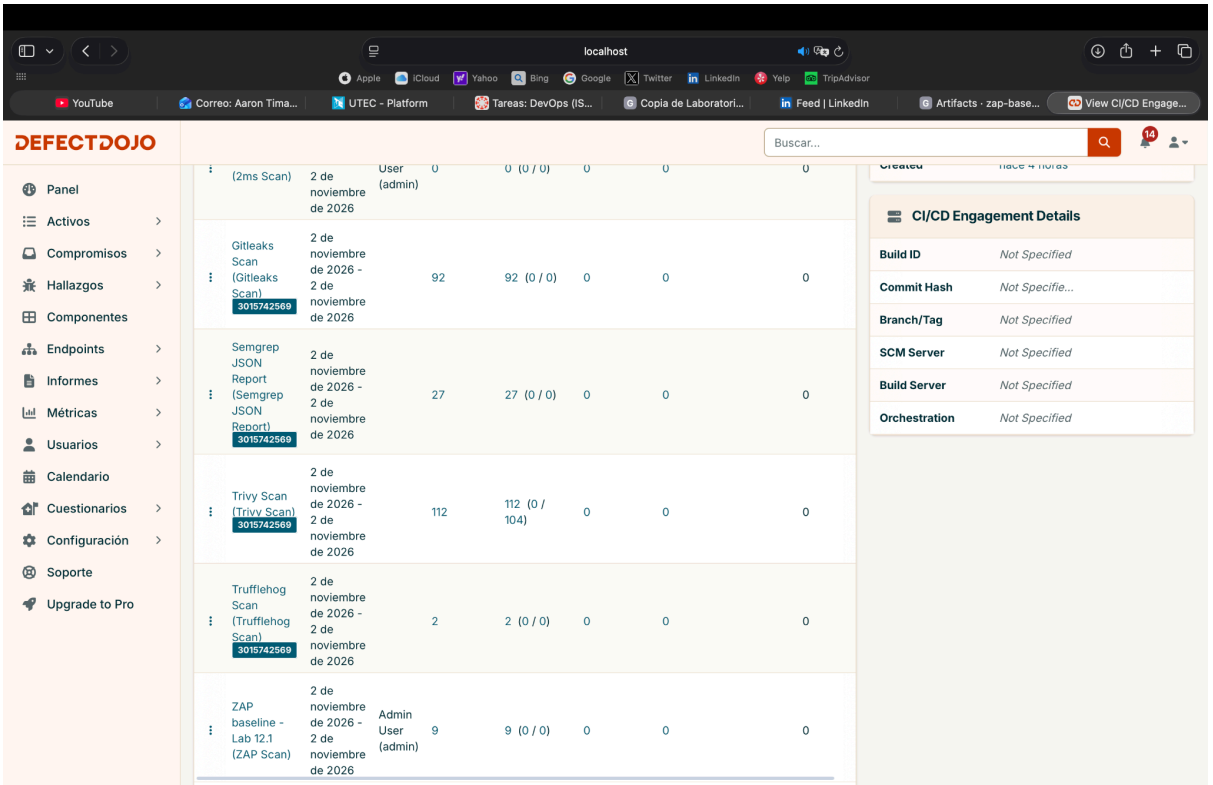

gitlab.com
Project
juice-shop-devsecops-20262
Aarón Timaná Castro / juice-shop-devsecops-20262 / Jobs / #17653013287
Retry
Failed
zap-baseline
Log timestamps in UTC.
Search visible log output
59 04:57:51 ETag: W/"2700-1a19a9e5c28"
60 04:57:51 Content-Type: text/html; charset=UTF-8
61 04:57:51 Content-Length: 9984
62 04:57:51 Vary: Accept-Encoding
63 04:57:51 Date: Mon, 02 Nov 2026 04:57:51 GMT
64 04:57:51 Connection: keep-alive
65 04:57:51 Keep-Alive: timeout=5
66 04:57:51 $ zap-baseline.py -t "$TARGET" -c rules.conf -r zap-report.html -J zap-report.json -x zap-report.xml -s
67 04:58:49 Using the Automation Framework
68 04:58:49 IGNORE: Storable and Cacheable Content [10049] x 6
69 04:58:49 IGNORE: Modern Web Application [10109] x 5
70 04:58:49 WARN-NEW: Deprecated Feature Policy Header Set [10063] x 5
71 04:58:49 WARN-NEW: Dangerous JS Functions [10110] x 2
72 04:58:49 WARN-NEW: Cross-Origin-Embedder-Policy Header Missing or Invalid [90004] x 10
73 04:58:49 FAIL-NEW: Content Security Policy (CSP) Header Not Set [10038] x 5
74 04:58:49 FAIL-NEW: Cross-Domain Misconfiguration [10098] x 4
75 04:58:49 FAIL-NEW: 2 FAIL-INPROG: 0 WARN-NEW: 3 WARN-INPROG: 0 INFO: 0 IGNORE: 2 PASS: 61
76 04:58:49 Running after_script 00:00
77 04:58:49 Running after script...
78 04:58:49 $ cp /zap/wrk/zap-report.* "$CI_PROJECT_DIR/" || true
79 04:58:49 Uploading artifacts for failed job 00:01
80 04:58:49 Uploading artifacts...
81 04:58:50 zap-report.html: found 1 matching artifact files and directories
82 04:58:50 zap-report.json: found 1 matching artifact files and directories
83 04:58:50 zap-report.xml: found 1 matching artifact files and directories
84 04:58:50 Uploading artifacts as "archive" to coordinator... 201 Created correlation_id=e2ccc8b17cb84e60ab8952ed15b92760 id=17653013287 status=201 token=75_YDnuGr
85 04:58:50 Cleaning up project directory and file based variables 00:01
86 04:58:51 ERROR: Job failed: exit code 1
Duration
1 minute 58 seconds
Finished
16 minutes ago
Queued
0 seconds
Timeout
1h (from project)
Runner
#54907241 (nezyxEJe) k8s.saas-linux-small-amd64.runners-manager.gitlab.com/default
Source
Push
Job artifacts
These artifacts are the latest. They will not be deleted (even if expired) until newer artifacts are available.
Keep
Download
Browse
Commit 5069a7f0
chore(ci): add ZAP baseline scanning wit h rule gates
Pipeline #3016200695 Failed for co

Artefacto:


gitlab.com
Project
juice-shop-devsecops-20262
Aarón Timaná Castro / juice-shop-devsecops-20262 / Jobs / #17653013287 / Artifacts
failed (allowed to fail) Job #17653013287 in pipeline #3016200695 for 5069a7f0 from codex/lab12-1-dast by Aarón Timaná Castro 19 minutes ago
Artifacts
Download artifacts archive
Name
Size
zap-report.html 80.5 KiB
zap-report.json 30 KiB
zap-report.xml 36.3 KiB

5. **Captura de DefectDojo** con los findings ZAP Scan junto a los de Semgrep, Trivy y Gitleaks (Parte 7, si la realizaste). Al menos 2 herramientas adicionales a zap




6. **Documento de reflexión** que responda:

- **¿Por qué el API scan devolvió sobre todo errores 5xx? ¿Qué necesitaría el equipo para que la capa activa sea útil?**
  El escaneo envió peticiones generadas automáticamente, sin un JWT de prueba ni cuerpos válidos para la operación de pedidos. Las respuestas 5xx muestran errores durante esas pruebas, pero no demuestran que se haya evaluado correctamente la lógica de negocio. El equipo debe proporcionar credenciales, permisos, datos de prueba y ejemplos válidos de cada operación para que ZAP alcance y pruebe esa lógica.
- **Semgrep encontró SQLi en routes/login.ts y ZAP no. ¿En qué condiciones DAST sí lo encontraría? ¿Qué escaneo y qué flags usarías?**
  Semgrep analiza el código; ZAP necesita alcanzar el endpoint de login y enviar payloads a sus parámetros. El baseline es pasivo y el API scan realizado se limitó al contrato B2B, que no cubre ese login. Usaría zap-full-scan.py con -j para explorar la SPA, -m 3 para limitar el spider y -T 60 para limitar la ejecución. Además, incluiría explícitamente una petición válida a /rest/user/login, con sus campos JSON, y comprobaría que las reglas activas de SQLi estén habilitadas. Esto mejora la cobertura, aunque no garantiza la detección.
- **Si fueras responsable del gate en un equipo con 800 repos legacy, ¿qué reglas pondrías en FAIL el primer mes?**
  Comenzaría bloqueando nuevas vulnerabilidades confirmadas de alto impacto, como SQLi, ejecución remota de código y exposición de credenciales. Mantendría inicialmente en WARN las cabeceras y otras mejoras generales, con responsables y plazos de corrección. Registraría los hallazgos existentes como línea base para introducir el gate gradualmente sin bloquear los 800 repositorios por toda su deuda histórica.